

# Secure Boot

General Notes - Vatsal Patel

# Executive Summary

## Problem Statement:

- The Firmware is modified/replaced with Malicious Firmware

## Outcome:

- Undefined and unauthorized operational behavior

## Attack Vector:

- Load Image through Debug Interface
- Software Update feature
- Modify Image in Memory or replace Memory itself

## Parallel Defence in Depth

- Secure Update  
(High Priority requirement of Cyber Resilience Act)
- Protection of Debug Interface

## Use case

- Critical Industrial applications of IT, OT, Defence, Finance, Energy

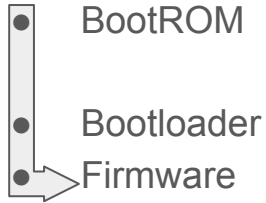


## Core Concern

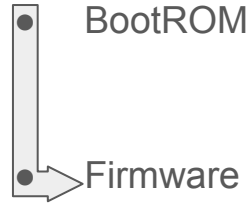
- Human Safety, Financial Integrity, Privacy, Disaster Protection

# Boot chain - Boot Stage Architecture

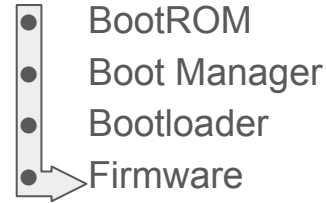
*Common*



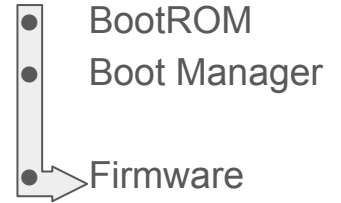
*Basic*



*Complex*



*Conditional*



## *Multiple Firmware*

## *Mechanism*

### **Failure / Fallback**

A/B Firmware

Update Mode

Fail Count

Factory Firmware

Recovery Mode

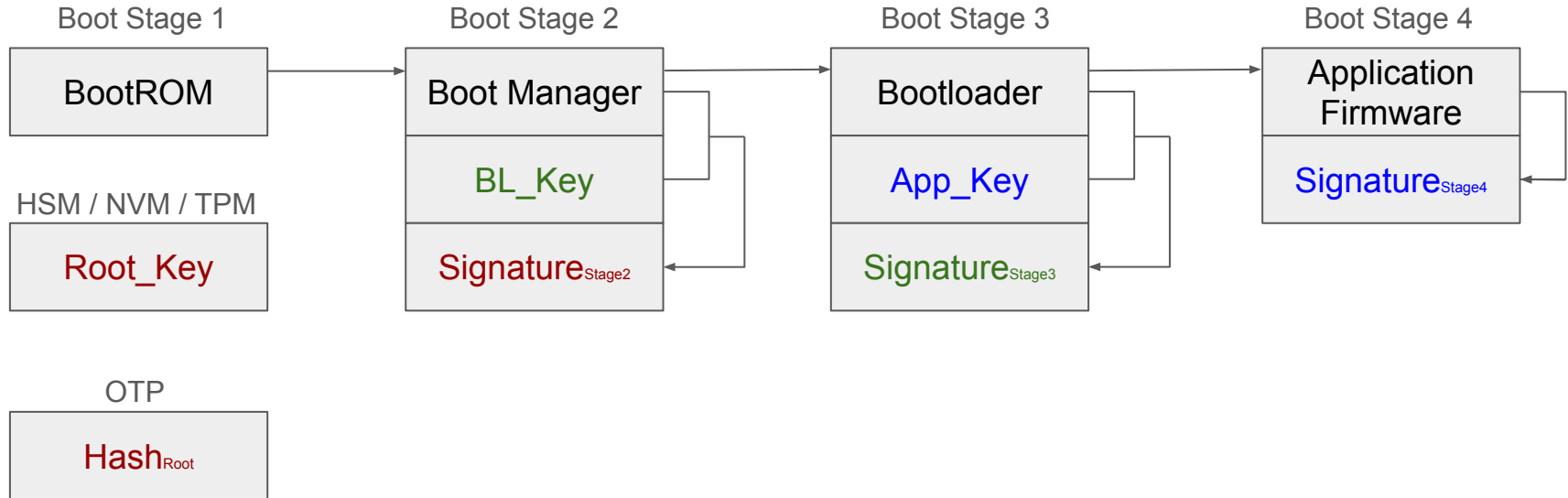
Power Reset

Recovery Firmware

Safe State

System Halt

# Boot chain - Boot Stage Architecture



# Different Security Level

## Hash based Secure Boot

### Usage

- Simple implementation and deployment
- Usable where, System/Device stays within protected and controlled environment

## Digital Signature based Secure Boot

### Usage

- Complex Implementation and deployment
- Usable mostly in Field with distributed customer based location

## Asymmetric Vs Symmetric

Asymmetric : Default preference for small to large scale

Symmetric : Niche use-case, for application with time and resource constraints and limited scale deployment

# Specific Features

- Multiple Root Public Key with revocation possibilities using OTP
- Update of any Boot stage
- Pre-execution of any stage in parallel to verification

# Design Considerations\*

- Include all the data (configuration, header) along with code and sign the complete package/container.
- Disablement of HW Boot configuration pins.

\*In addition to general requirements

# Cryptographic considerations

|                  |                                                                                  |
|------------------|----------------------------------------------------------------------------------|
| <i>HASH</i>      | Minimum SHA-384, SHA-512                                                         |
| <i>MAC</i>       | AES-CMAC or AES-GMAC - Key length 192 bits or longer                             |
| <i>Signature</i> | RSASSA-PSS : Key length minimum 4K or longer, mgf1,<br>Salt length = HASH length |
|                  | ECDSA :                   secp384r1, secp521r1                                   |
|                  | EdDSA :                   ed25519                                                |

## Attack Vectors against Secure Boot

- Fault Injection / Glitching
- Off-Chip Code/Data - TOCTOU
- Key Compromise

# BootROM

## Key Characteristic

- Hardware defined Immutable Code

## Security Perspective

- Root of Trust / Hardware Trust Anchor
- Holds Public Key to verify  
Authenticity / Integrity of  
Boot Manager / Bootloader / Firmware

# Protection Methods for Root of Trust (BootROM & Keys)

**Mask ROM** – Permanently embed Code (BootROM) during chip manufacturing.

**OTP/eFuse** – Programmable once and then Physically locked.

- Permanent Security Configurations/data:  
Secure Boot enable/disable, Root-of-trust public-key hash, Device/lifecycle state DEV/PROD, Debug/JTAG lock configuration, Device-specific IDs

**Hardware Security Module (HSM)** – key stored/used inside isolated security hardware.

- Keys, Certificates, Counters and Crypto Functionality

**Secure Element** – External tamper-resistant chip stores the root key.

**Secure NVM** – Protected non-volatile storage accessible only by secure hardware.

- Encrypted Flash Storage, Protected internal Flash — access controlled by MCU security mechanisms

**PUF-derived key** – Key not stored, derived from device-specific physical characteristics. (Physical Unclonable Function)

# Boot Manager

## Key Characteristics

- Based on Design, Initialize essential Hardware - Clock, CPU, RAM, ROM
- Verify boot Conditions / Policy
  - Version, Configuration, Update check, Image / Slot Preference
- Firmware Management
  - Decide Bootloader / Firmware
  - Firmware selection from multiple Images / Slots
  - Update, Rollback or Recovery
- Pass the control to the selected Bootloader / Firmware

## Security Perspective

- Verified by BootROM
- Holds the Public key to verify Authenticity / Integrity of Bootloader Signature or Firmware Signature

# Bootloader

## Key Characteristics

- Based on Design, Initialize essential Hardware - Clock, CPU, RAM, ROM
- Firmware Management
  - Locating and Loading of Firmware
    - Internal / External Memory
  - Update
- Pass the Control to selected Firmware

## Security Perspective

- Verified by BootROM or Boot Manager
- Holds the Public key to verify Authenticity / Integrity of Firmware Signature

# Firmware

## Key Characteristics

- Main Software/Firmware

## Security Perspective

- Verified by Boot Manager or Bootloader